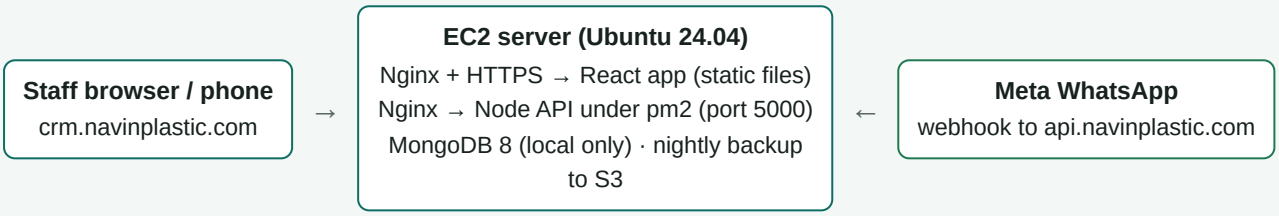
NAVIN PLASTIC TECH · CRM / ERP

# Going live on AWS

Choose the EC2 server, connect your domain, install the app with HTTPS, and switch on WhatsApp. Every step, in order.

Version of 13 October 2026 · Written for the code on `main` of `Npt_server-` and `Npt_web-` · About 2 hours of work, plus 1–3 days waiting on Meta for WhatsApp.

**What you will end up with** — one server in AWS Mumbai





1 Before you start: values to collect
2 EC2 options and monthly cost
3 Launch (or resize) the instance
4 Domain and DNS settings
5 Server setup: Node, MongoDB, swap
6 Install the API and the web app
7 Nginx and HTTPS certificates
8 Keep it running, first admin, checks
9 Backups and the disk alarm
10 Deploying updates
11 WhatsApp: Meta account and number
12 WhatsApp: token, server, webhook
13 WhatsApp: message templates
14 WhatsApp: screenshots to draft enquiries
15 Test it end to end
16 Troubleshooting
A Go-live checklist


The example names `crm.navinplastic.com` and `api.navinplastic.com` are used throughout. Replace them with your real domain everywhere you see them. `<ELASTIC_IP>` means your server's fixed IP address. AWS prices are approximate on-demand prices for the Mumbai region, in US dollars, before 18% GST; check the AWS Pricing Calculator before you commit.

# 1 Before you start

## What you need in hand

☐ An AWS account with a payment card, signed in as an admin (not the root user for daily work).

☐ Access to the domain's DNS panel, wherever the domain was bought (Hostinger, GoDaddy, BigRock…).

☐ Access to both GitHub repositories, `nrsnavin/Npt_server-` and `nrsnavin/Npt_web-`.

☐ The company email account's SMTP details (for sign-in codes and quotation emails).

☐ For WhatsApp: a Meta (Facebook) login with admin rights on the business, the GST certificate or Udyam registration, and a phone number that is **not** on the WhatsApp app.

☐ On Windows: PowerShell or PuTTY for SSH. On Mac/Linux: the Terminal.

## Fill this in as you go

Keep this sheet private. It holds passwords. Never paste these values into WhatsApp, email or a ticket.

| Value | Where it comes from | Yours |
|---|---|---|
| Web app address | You choose (Part 4) | crm._____ |
| API address | You choose (Part 4) | api._____ |
| Elastic IP | AWS, Part 3 | |
| SSH key file `npt-erp.pem` | AWS, Part 3 (keep 2 copies offline) | |
| MongoDB admin password | You make up, Part 5 | |
| `JWT_SECRET` | `openssl rand -base64 48`, Part 6 | |
| SMTP host / user / password | Your mail provider | |
| `META_WA_TOKEN` | Meta, Part 12 | |
| `META_WA_PHONE_NUMBER_ID` | Meta, Part 12 | |
| `META_WA_APP_SECRET` | Meta, Part 12 | |
| `META_WA_VERIFY_TOKEN` | `openssl rand -hex 32`, Part 12 | |
| `ANTHROPIC_API_KEY` (optional) | console.anthropic.com, Part 14 | |

## How to read the commands

- Grey-on-dark boxes are commands. Copy them one box at a time and press Enter.
- If a box starts with `cd`, the folder matters. If not, the command works from anywhere.
- In `nano` (the text editor): save with **Ctrl O**, then **Enter**; exit with **Ctrl X**.
- Lines starting with `#` are comments; they do nothing if pasted.

# 2 EC2 options and monthly cost

The app needs memory more than CPU: MongoDB, two Node processes and Nginx share the box. The figures below come from the app's own load tests (`npm run load-test:50`: fifty people signing in at once and working the enquiry flow).

## Instance size

| Type | vCPU / RAM | Approx. per month | Who it suits | Verdict |
|---|---|---|---|---|
| `t2.micro` / `t3.micro` | 1–2 / 1 GB | $8–9 (free tier for 12 months) | Trying the app alone | Not for staff use<br>MongoDB + Node on 1 GB gets killed for memory during imports and builds; it looks like the app randomly dying. |
| `t3.small` | 2 / 2 GB | about $16 | Up to 25 people at once | Recommended start<br>Run 1 API process and the 2 GB swap file. |
| `t3a.small` | 2 / 2 GB | about $15 | Same as t3.small | AMD version, ~10% cheaper, same steps |
| `t4g.small` | 2 / 2 GB (ARM) | about $13 | Same as t3.small | Cheapest 2 GB. Pick the **arm64** Ubuntu image; every step here works unchanged |
| `t3.medium` | 2 / 4 GB | about $33 | 25–50 people at once | Growth<br>Run 2 API processes (the default) and Redis. |

> **Measured on 2 cores, 50 people:** one API process kept the slowest 5% of reads at 0.63 s and handled about 23 actions a second; two processes did 0.48 s and about 32 actions a second. Neither produced an error. Start on `t3.small` and resize later in five minutes (Part 3) if it feels slow.

## Other monthly costs

| Item | Size | Approx. per month |
|---|---|---|
| Disk (EBS gp3) | 40 GB lasts about 3 years of photos and documents | about $3.70 |
| Fixed public IP (Elastic IP) | 1 address. AWS charges for every public IPv4 address, attached or not | about $3.70 |
| Backups in S3 | about 6–8 GB after a year | under $0.50 |
| Data out to the internet | first 100 GB a month free; this app uses a few GB | $0 |
| WhatsApp (Meta, not AWS) | charged per message by Meta; replies to a buyer within 24 h of their message are free | depends on volume |

**Typical total on t3.small: about $24 a month** plus 18% GST (AWS India bills through AISPL). A 1-year Compute Savings Plan lowers the instance part by roughly a third once you are sure of the size.

### Three ways to host it

#### A. One EC2 server this guide

API, web app and MongoDB on one box. Cheapest and simplest. You own patching and backups (Part 9 sets those up).

**Cost:** about $24/month.

#### B. EC2 + MongoDB Atlas

The database moves to MongoDB's managed service in Mumbai (`ap-south-1`), with its own backups and a replica set built in. Skip the MongoDB steps in Part 5 and put Atlas's connection string in `MONGO_URI`. Choose this when losing a day of data is not acceptable.

**Cost:** EC2 as above, plus Atlas: a dedicated M10 is roughly $55–60/month. Check atlas pricing for the current tiers.

#### C. Amazon Lightsail

The same Ubuntu server as a fixed bundle: the 2 GB plan (about $12/month) and 4 GB plan (about $24/month) include the IP address, disk and data transfer. Every command in this guide works; only the console screens differ (Networking tab for the firewall and a static IP). Simpler billing, fewer AWS features later.

> **Recommendation:** Option A on `t3.small` (or `t4g.small`), 40 GB gp3, in Mumbai. Move to `t3.medium` when more than 25 people use it at the same time.

# 3 Launch (or resize) the instance

## 3.1 Pick the region

Top-right of the AWS console, choose **Asia Pacific (Mumbai) ap-south-1**. It is the closest to Tiruppur, so every click is faster.

## 3.2 Launch

EC2 → Instances → Launch instances

| Field | Value |
|---|---|
| Name | `npt-erp` |
| Application and OS image | **Ubuntu Server 24.04 LTS**, 64-bit (x86) — or 64-bit (Arm) if you chose `t4g.small` |
| Instance type | `t3.small` (see Part 2) |
| Key pair | Create new → name `npt-erp`, type RSA, format `.pem` (or `.ppk` for PuTTY). Download it and keep two copies offline. It is the only way in. |
| Network settings | Create security group `npt-erp-sg` with the rules in 3.3 |
| Storage | **40 GiB, gp3** |

Click **Launch instance**.

## 3.3 Security group (the firewall)

| Type | Port | Source | Why |
|---|---|---|---|
| SSH | 22 | **My IP** | Never `0.0.0.0/0`: an open SSH port is attacked within minutes. Update it if your office IP changes. |

| | | | |
|---|---|---|---|
| HTTP | 80 | Anywhere (0.0.0.0/0) | Needed for the HTTPS certificate; then redirects to HTTPS |
| HTTPS | 443 | Anywhere (0.0.0.0/0) | The app and the WhatsApp webhook |

> **Do not open port 27017 (MongoDB) or 5000 (the API).** Both stay private to the server; Nginx is the only way in from outside.

### 3.4 Fixed IP address (Elastic IP)

1. EC2 → Network & Security → Elastic IPs → Allocate Elastic IP address → Allocate.
2. Select it → **Actions** → **Associate Elastic IP address** → choose the `npt-erp` instance → Associate.
3. Write the address on your sheet as `<ELASTIC_IP>`. Without it, the IP changes on every stop/start and your domain points at nothing.

### 3.5 Already running on a t2.micro? Resize it

No reinstall is needed. Data, disk and Elastic IP stay as they are. Expect about 5 minutes of downtime, so do it outside working hours.

1. Take a backup first: EC2 → Volumes → select the volume → Actions → Create snapshot.
2. EC2 → Instances → select it → Instance state → Stop instance. Wait for **Stopped**.
3. Actions → Instance settings → Change instance type → `t3.small` → Apply.
4. **Instance state** → **Start instance**. Then on the server: `pm2 status` should show `npt-api` online.

Ubuntu 22.04/24.04 images already have the drivers a t3 needs. Moving x86 → ARM (t4g) is not a resize; that needs a new instance.

### 3.6 Connect over SSH

```
# Mac / Linux / Windows PowerShell — run from the folder holding the key
chmod 400 npt-erp.pem            # Mac/Linux only
ssh -i npt-erp.pem ubuntu@<ELASTIC_IP>
```

Answer `yes` to the fingerprint question the first time. You are in when the prompt reads `ubuntu@ip-…:~$`.

# 4 Domain and DNS settings

The app uses two names on your domain: one for the screens people open, one for the API (which the WhatsApp webhook also calls). Do this **right after Part 3**: DNS takes minutes to an hour to spread, and HTTPS certificates (Part 7) cannot be issued until it has.

| Name | Example | What it serves |
|---|---|---|
| Web app | `crm.navinplastic.com` | The React screens staff open in a browser or install as an app |
| API | `api.navinplastic.com` | The server the screens talk to; WhatsApp posts messages here |

### 4.1 Add two A records at your DNS provider

Hostinger: Domains → your domain → DNS / Nameservers → DNS records. GoDaddy: My Products → Domain → DNS → Add New Record. Others: look for "DNS management" or "Zone editor".

| Type | Name / Host | Points to / Value | TTL |
|---|---|---|---|
| A | `crm` | `<ELASTIC_IP>` | 300 (or the lowest offered) |
| A | `api` | `<ELASTIC_IP>` | 300 |

- Type only `crm` in the Name box, not `crm.navinplastic.com`; the panel adds the domain itself.
- If a `crm` or `api` record already exists (A or CNAME), edit it instead of adding a second one.
- **Leave MX, TXT, SPF and DKIM records alone.** They carry your company email. Adding subdomains does not affect email; deleting the wrong row does.
- Optional: to send people who type the bare domain to the CRM, add a redirect in the DNS panel ("Forwarding") from `navinplastic.com` to `https://crm.navinplastic.com`. Only do this if the bare domain does not already host your company website.

### 4.2 Using Route 53 instead (optional)

Only if you want AWS to hold the DNS (about $0.50/month): Route 53 → Hosted zones → Create hosted zone for `navinplastic.com`, copy **every** existing record (especially MX and TXT for email) into it, add the two A records above, then replace the nameservers at your registrar with the four Route 53 shows. Copy the email records first, or company email stops. If unsure, stay with 4.1.

### 4.3 Check that the names resolve

```
# On the server, or any Mac/Linux terminal
dig +short crm.navinplastic.com
dig +short api.navinplastic.com
# On Windows
nslookup crm.navinplastic.com
```

Both must print `<ELASTIC_IP>` before you run the certificate step in Part 7. If they print nothing, wait 10 minutes and try again.

### 4.4 Where the domain names go in the app

The same two names appear in several places. A mismatch in any one shows up as a confusing error, so set them all exactly as below: `https://`, no trailing slash.

| Setting | File | Value |
|---|---|---|
| `CORS_ORIGIN` | server `.env` | `https://crm.navinplastic.com` |
| `APP_URL` | server `.env` | `https://crm.navinplastic.com` (links in emails and WhatsApp) |
| `PUBLIC_API_URL` | server `.env` | `https://api.navinplastic.com/api` (PDF links WhatsApp downloads) |
| `VITE_API_URL` | web `.env.production` | `https://api.navinplastic.com/api` (built in; rebuild after a change) |
| `server_name` | Nginx config | one block each for `crm.…` and `api.…` |
| `connect-src` | Nginx security snippet | `https://api.navinplastic.com` |
| Callback URL | Meta app → WhatsApp → Configuration | `https://api.navinplastic.com/api/whatsapp/inbound` |

# 5 Server setup: Node, MongoDB, swap

## 5.1 Updates, tools and the firewall

```
sudo apt update && sudo apt upgrade -y
sudo apt install -y git nginx ufw curl
sudo ufw allow OpenSSH
sudo ufw allow 'Nginx Full'
sudo ufw --force enable
```

## 5.2 Swap file (stops builds from crashing a 2 GB server)

```
sudo fallocate -l 2G /swapfile
sudo chmod 600 /swapfile
sudo mkswap /swapfile
sudo swapon /swapfile
echo '/swapfile none swap sw 0 0' | sudo tee -a /etc/fstab
free -m        # the Swap line should show about 2047
```

## 5.3 Node.js 22

```
curl -fsSL https://deb.nodesource.com/setup_22.x | sudo -E bash -
sudo apt install -y nodejs
node -v        # v22.x
```

## 5.4 MongoDB 8

Skip 5.4–5.6 if you chose MongoDB Atlas (option B).

```
curl -fsSL https://www.mongodb.org/static/pgp/server-8.0.asc | \
  sudo gpg -o /usr/share/keyrings/mongodb-server-8.0.gpg --dearmor
echo "deb [ arch=amd64,arm64 signed-by=/usr/share/keyrings/mongodb-server-8.0.gpg ]
https://repo.mongodb.org/apt/ubuntu noble/mongodb-org/8.0 multiverse" | \
  sudo tee /etc/apt/sources.list.d/mongodb-org-8.0.list
sudo apt update && sudo apt install -y mongodb-org
sudo systemctl enable --now mongod
grep bindIp /etc/mongod.conf     # must say 127.0.0.1
```

## 5.5 Create the database admin

Make up a long password with letters and digits only (symbols like `@ : /` break the connection string). Write it on your sheet.

```
mongosh --eval 'db.getSiblingDB("admin").createUser({ user: "nptadmin", pwd: "PUT-YOUR-LONG-
PASSWORD", roles: [{ role: "root", db: "admin" }] })'
```

## 5.6 Turn on passwords and transactions

The app saves related records together (an order and its number, a customer and its first enquiry). MongoDB does that only as a **replica set**, so this makes the single server a one-node replica set. Same data, same port.

```
openssl rand -base64 756 | sudo tee /etc/mongod-keyfile >/dev/null
sudo chown mongodb:mongodb /etc/mongod-keyfile
sudo chmod 400 /etc/mongod-keyfile
sudo nano /etc/mongod.conf
```

Find the line `#security:` and replace it (and any `#replication:` line) with these lines, keeping the two-space indents:

```
security:
  authorization: enabled
  keyFile: /etc/mongod-keyfile
replication:
  replSetName: rs0
```

```
sudo systemctl restart mongod
mongosh -u nptadmin -p --authenticationDatabase admin \
  --eval 'rs.initiate({ _id: "rs0", members: [{ _id: 0, host: "127.0.0.1:27017" }] })'
# It asks for the password; the answer should include  ok: 1
```

### 5.7 Redis (only with two API processes, on t3.medium)

```
sudo apt install -y redis-server
sudo systemctl enable --now redis-server
redis-cli ping      # PONG
```

Then add `REDIS_URL=redis://127.0.0.1:6379` to the server `.env` in Part 6. On t3.small with one API process, skip Redis.

# 6 Install the API and the web app

### 6.1 Get the code

The repositories are private, so git asks for a username and password. Use your GitHub username and a **fine-grained personal access token** (GitHub → Settings → Developer settings → Personal access tokens → Fine-grained → Generate; only these two repositories; Contents: Read-only).

```
sudo mkdir -p /srv/npt && sudo chown ubuntu:ubuntu /srv/npt
cd /srv/npt
git config --global credential.helper store     # remembers the token for later updates
git clone https://github.com/nrsnavin/Npt_server-.git server
git clone https://github.com/nrsnavin/Npt_web-.git web
```

### 6.2 The API settings file

```
cd /srv/npt/server
npm ci --omit=dev
openssl rand -base64 48        # copy the output: it is your JWT_SECRET
nano .env
```

Paste this, then replace every capitalised placeholder:

```
NODE_ENV=production
PORT=5000
# Database (Part 5). With Atlas, paste Atlas's connection string instead.
MONGO_URI=mongodb://nptadmin:PUT-YOUR-LONG-PASSWORD@127.0.0.1:27017/npt_erp?
authSource=admin&replicaSet=rs0

# Sign-in security. The API refuses to start with a short or default value.
JWT_SECRET=PASTE-THE-48-CHARACTER-STRING
JWT_EXPIRES_IN=7d
```

```
# Your domain (Part 4). https://, no trailing slash.
CORS_ORIGIN=https://crm.navinplastic.com
APP_URL=https://crm.navinplastic.com
PUBLIC_API_URL=https://api.navinplastic.com/api

# REDIS_URL=redis://127.0.0.1:6379      # only with two processes (Part 5.7)

# Email: sign-in codes, quotations, LR copies.
# Hostinger mail: smtp.hostinger.com / 465. Google Workspace: smtp.gmail.com / 587 + an App
Password.
SMTP_HOST=smtp.hostinger.com
SMTP_PORT=465
SMTP_USER=info@navinplastic.com
SMTP_PASSWORD=THE-MAILBOX-PASSWORD
SMTP_FROM=Navin Plastic Tech <info@navinplastic.com>
DEFAULT_COUNTRY_CODE=+91
OTP_EXPOSE_IN_RESPONSE=false

# WhatsApp goes here later (Part 12). Optional extras:
# ANTHROPIC_API_KEY=      reads screenshots and visiting cards (Part 14)
# INDIAMART_CRM_KEY=      the IndiaMART lead feed
```

```
chmod 600 .env       # only you can read it
```

> **Never commit `.env` to git or send it to anyone.** If a password was ever shared in chat or email, change it at the source before going live.

### 6.3 Build the web app

The API address is baked into the build, so set it before building:

```
cd /srv/npt/web
npm ci
echo 'VITE_API_URL=https://api.navinplastic.com/api' > .env.production
npm run build        # creates /srv/npt/web/dist — takes 1–3 minutes
```

# 7 Nginx and HTTPS certificates

### 7.1 Security headers (one shared snippet)

```
sudo nano /etc/nginx/snippets/npt-security.conf
```

```
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "DENY" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "camera=(), microphone=(), geolocation=()" always;
add_header Content-Security-Policy "default-src 'self'; script-src 'self'; style-src 'self'
'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src
'self' data: blob:; connect-src 'self' https://api.navinplastic.com; manifest-src 'self'; worker-
src 'self'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'; object-src 'none'"
always;
```

## 7.2 The two sites

```
sudo nano /etc/nginx/sites-available/npt
```

```
# The web app
server {
    listen 80;
    server_name crm.navinplastic.com;
    root /srv/npt/web/dist;
    index index.html;
    include snippets/npt-security.conf;

    location / { try_files $uri $uri/ /index.html; }      # reload on any screen works
    location = /index.html {
        add_header Cache-Control "no-cache";
        include snippets/npt-security.conf;
    }
    location /assets/ {
        expires 1y;
        add_header Cache-Control "public, immutable";
        include snippets/npt-security.conf;
        try_files $uri @previous;                          # tabs open across a deploy
    }
    location @previous {
        root /srv/npt/web/dist.old;
        expires 1y;
        add_header Cache-Control "public, immutable";
        include snippets/npt-security.conf;
    }
    gzip on;
    gzip_types text/css application/javascript application/json image/svg+xml;
}

# The API (and the WhatsApp webhook)
server {
    listen 80;
    server_name api.navinplastic.com;
    client_max_body_size 25M;                              # phone photos and PDFs

    location / {
        proxy_pass http://127.0.0.1:5000;
        proxy_http_version 1.1;
        proxy_set_header Host              $host;
        proxy_set_header X-Real-IP         $remote_addr;
        proxy_set_header X-Forwarded-For   $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
        proxy_read_timeout 60s;
    }
}
```

```
sudo ln -s /etc/nginx/sites-available/npt /etc/nginx/sites-enabled/
sudo rm -f /etc/nginx/sites-enabled/default
sudo nginx -t && sudo systemctl reload nginx      # must say "syntax is ok"
```

## 7.3 Free HTTPS certificates (Let's Encrypt)

Only after Part 4.3 shows both names pointing at your Elastic IP:

```
sudo snap install --classic certbot
sudo ln -sf /snap/bin/certbot /usr/bin/certbot
sudo certbot --nginx -d crm.navinplastic.com -d api.navinplastic.com
sudo certbot renew --dry-run       # proves automatic renewal works
```

Give an email for expiry notices, agree to the terms, and choose **redirect** if asked. Certificates renew by themselves every 60–90 days.

After HTTPS works for a week, you may add `add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;` to the snippet. Browsers then refuse plain http for a year, so add it only once HTTPS is solid.

# 8 Keep it running, first admin, checks

## 8.1 Start the API with pm2

```
sudo npm install -g pm2
cd /srv/npt/server
# t3.small (2 GB): one API process
API_INSTANCES=1 pm2 start ecosystem.config.cjs
# t3.medium (4 GB) with Redis: two processes, the default
# pm2 start ecosystem.config.cjs
pm2 save
pm2 startup systemd -u ubuntu --hp /home/ubuntu
# it prints one "sudo env PATH=..." line: copy and run that line too
```

> **Why the number is on the command line:** pm2 reads `API_INSTANCES` when it starts, not from `.env`. After `pm2 save` it remembers the count, and later reloads keep it. To change from one to two processes later: `pm2 delete npt-api`, then `pm2 start ecosystem.config.cjs` and `pm2 save`.

```
pm2 status                     # npt-api: online
pm2 logs npt-api --lines 30    # ends with "listening on port 5000" and "MongoDB connected"
```

## 8.2 Create the first admin

```
cd /srv/npt/server
npm run create-user -- rsnavin1@gmail.com 'A-STRONG-PASSWORD' --role=admin --name="Navin R"
```

Open **https://crm.navinplastic.com** and sign in. Then add staff under **Masters & Access → Users**, with each person's department and WhatsApp number.

> **Do not run `npm run seed` on the live server.** It deletes all users and loads demo data.

## 8.3 Health checks

```
curl -s https://api.navinplastic.com/health          # the API is up
curl -s https://api.navinplastic.com/health/ready    # up + database; shows "transactions": true
sudo systemctl status mongod nginx --no-pager
df -h /  &&  free -m
```

`"transactions": true` confirms Part 5.6 worked. `delivery.whatsapp` reads `console` until Part 12 is done, then `meta`.

# 9 Backups and the disk alarm

The database and the uploaded files cannot be rebuilt from git. A backup on the same disk is not a backup, so both go to S3 every night.

## 9.1 An S3 bucket and a backup user

1. S3 → Create bucket: name `npt-erp-backups-<something unique>`, region Mumbai, **Block all public access** on, **Bucket versioning: Enable**.
2. IAM → Users → Create user `npt-backup` → attach a policy allowing `s3:PutObject`, `s3:GetObject`, `s3:ListBucket` on that bucket only → **Security credentials** → **Create access key** (type "Command Line Interface").
3. Optional saving: in the bucket, add a lifecycle rule moving `uploads/` to Standard-IA after 30 days and expiring old versions after 90.

```
sudo snap install aws-cli --classic
aws configure          # paste the key and secret; region ap-south-1; output json
```

## 9.2 The nightly script

```
mkdir -p /srv/npt/backups
nano /srv/npt/backup.sh
```

```
#!/bin/bash
set -euo pipefail
STAMP=$(date +%F-%H%M)
OUT=/srv/npt/backups
BUCKET=s3://npt-erp-backups-YOURNAME
mongodump --uri="mongodb://nptadmin:PUT-YOUR-LONG-PASSWORD@127.0.0.1:27017/npt_erp?
authSource=admin" \
  --archive="$OUT/npt-$STAMP.archive" --gzip
find "$OUT" -type f -name '*.archive' -mtime +14 -delete      # keep 14 nights on the box
aws s3 sync "$OUT" "$BUCKET/db/" --exclude '*.log'
aws s3 sync /srv/npt/server/uploads "$BUCKET/uploads/"
```

```
chmod 700 /srv/npt/backup.sh
/srv/npt/backup.sh             # run once now; check the files appear in S3
crontab -e                     # add the line below: every night at 2 am
0 2 * * * /srv/npt/backup.sh >> /srv/npt/backups/backup.log 2>&1
```

The server clock is UTC: 2 am UTC is 7:30 am in India. Use `30 20 * * *` for 2 am India time.

## 9.3 Restore (test this once before you need it)

```
mongorestore --uri="mongodb://nptadmin:PUT-YOUR-LONG-PASSWORD@127.0.0.1:27017/?authSource=admin"
\
  --archive=/srv/npt/backups/npt-2026-10-13-0200.archive --gzip --drop
```

## 9.4 Disk alarm

A full disk stops MongoDB and the whole app. Simplest check: `df -h /` every week, and grow the disk at 75% (EC2 → Volumes → Modify, then `sudo growpart /dev/nvme0n1 1 && sudo resize2fs /dev/nvme0n1p1`, no

downtime). For an automatic email, install the CloudWatch agent with the `disk used_percent` metric and create an alarm at 75%.

Also: EC2 → Elastic Block Store → Lifecycle Manager can snapshot the whole disk every night (a few dollars a month) as a second layer.

# 10 Deploying updates

When new work is merged to `main`, put it on the server with one script.

```
nano /srv/npt/deploy.sh
```

```
#!/bin/bash
set -euo pipefail
echo "→ API"
cd /srv/npt/server
git pull origin main
npm ci --omit=dev
pm2 reload npt-api --update-env       # new process starts before the old stops

echo "→ Web"
cd /srv/npt/web
git pull origin main
npm ci
rm -rf dist.old && cp -r dist dist.old   # keep the previous build for open tabs
npm run build
echo "✓ deployed"
```

```
chmod +x /srv/npt/deploy.sh
/srv/npt/deploy.sh
curl -s https://api.navinplastic.com/health/ready
```

- Deploy outside busy hours when you can. A reload drops no requests, but a bad release affects everyone.
- Staff do not need to do anything; open screens pick up the new version on their next page change.
- **Data scripts (migrations) never run by themselves.** When a release note asks for one: take a backup (Part 9), run it once without `--confirm` to see what it would change, then with `--confirm`.
- Roll back the web app: `cd /srv/npt/web && mv dist dist.bad && mv dist.old dist`. Roll back the API: `cd /srv/npt/server && git reset --hard <previous commit> && npm ci --omit=dev && pm2 reload npt-api`.

> **Automatic deploys (later).** A GitHub self-hosted runner on the box can run `deploy/on-box.sh` after each merge, with a health check and automatic rollback. The full steps are in `docs/DEPLOY-AWS.md` §11 in the server repository. Start with the manual script; add the runner once things are stable.

# 11 WhatsApp: Meta account and number

The app talks to WhatsApp through **Meta's WhatsApp Cloud API** directly, with no middleman. Once set up it:

- sends quotations, LR copies, sample updates and trip notices to buyers, with the PDF;
- sends department-task notices to staff on their own numbers;
- receives buyer replies and photos into the WhatsApp inbox, and staff screenshots into Draft enquiries;
- can send sign-in codes to people who sign in with a phone number.

Until it is set up, the app still works; messages it would have sent are written to the server log instead.

> **Do Parts 3–8 first.** Meta needs the API live on HTTPS (Part 7) before the webhook in Part 12 can be verified. You can start Meta's business verification (step 2 below) on day one, because that is the slow part.

Meta renames its screens often. Look for the words in quotes rather than an exact path.

1. **Business portfolio.** Open `business.facebook.com`, create or choose the portfolio *Navin Plastic Tech*. Fill in the legal name, address and website exactly as on the GST certificate.
2. **Business verification.** Settings → "Security centre" → "Start verification". Upload the GST certificate or Udyam registration. Meta usually answers in 1–2 working days.
3. **Create the app.** `developers.facebook.com` → "My Apps" → "Create app" → type "Business" → name *NPT CRM* → link it to the Navin Plastic Tech portfolio.
4. **Add WhatsApp.** On the app dashboard, WhatsApp → "Set up". Meta creates a WhatsApp Business Account and a free test number.
5. **Add your real number.** WhatsApp → "API Setup" → "Add phone number": display name *Navin Plastic Tech*, category *Manufacturing*, then confirm the number with the code Meta sends by SMS or call.
   The number must not be on the WhatsApp or WhatsApp Business app. If it is, delete the account in that app first (Settings → Account → Delete account) and wait a few minutes.
6. **Display name.** Meta reviews it, usually within a day. Until then, messages show the number instead of the name.
7. **Billing.** WhatsApp Manager (`business.facebook.com/wa/manage`) → "Payment settings" → add a card. Without it, only replies inside a buyer's 24-hour window go out.

# 12 WhatsApp: token, server, webhook

## 12.1 Get the four values from Meta

Use a **System User** token. The temporary token on the API Setup page expires in 24 hours, and sending stops when it does.

1. **System user.** Business settings → Users → "System users" → "Add" → name *npt-server*, role Admin.
2. **Assign assets.** On that user, "Assign assets": the app *NPT CRM* (full control) and the WhatsApp account (full control).
3. **Token.** "Generate new token" → app *NPT CRM* → expiry **Never** → tick `whatsapp_business_messaging` and `whatsapp_business_management` → Generate. Copy it at once; Meta shows it only once.
4. **Phone number ID.** App → WhatsApp → "API Setup" → choose your real number in "From" → copy the "Phone number ID" (a long ID, not your phone number).

5. **App secret.** App settings → "Basic" → "App secret" → Show → copy.
6. **Verify token.** On the server run `openssl rand -hex 32` and copy the output.

| Setting | Looks like | From |
|---|---|---|
| `META_WA_TOKEN` | starts `EAA…`, very long | System users → Generate token |
| `META_WA_PHONE_NUMBER_ID` | 15–16 digits | App → WhatsApp → API Setup |
| `META_WA_APP_SECRET` | 32 letters and digits | App settings → Basic |
| `META_WA_VERIFY_TOKEN` | 64 letters and digits | You, with `openssl rand -hex 32` |

> Anyone holding the token can send WhatsApp messages as Navin Plastic Tech. Keep it only in the server's `.env`.

## 12.2 Put them on the server

```
cd /srv/npt/server
nano .env
```

Add this block (no quotes, no spaces around `=`):

```
WHATSAPP_PROVIDER=meta
META_WA_TOKEN=EAA...
META_WA_PHONE_NUMBER_ID=1234567890123456
META_WA_APP_SECRET=...
META_WA_VERIFY_TOKEN=...
META_WA_TEMPLATE_LANGUAGE=en
# already set in Part 6: PUBLIC_API_URL=https://api.navinplastic.com/api
```

```
pm2 reload npt-api --update-env
curl -s https://api.navinplastic.com/health/ready     # "whatsapp":"meta" under delivery
```

## 12.3 Connect the webhook (messages coming in)

1. developers.facebook.com → your app → WhatsApp → "Configuration" → Webhook → "Edit".
2. Callback URL: `https://api.navinplastic.com/api/whatsapp/inbound`
   Verify token: the same value as `META_WA_VERIFY_TOKEN`.
3. "Verify and save". The server log (`pm2 logs npt-api`) shows `webhook verified by Meta`.
4. "Webhook fields" → "Manage" → subscribe to **messages** (it carries incoming messages and delivery reports).
5. **Switch the app to Live.** App settings → Basic → add a privacy policy URL (a page on your website) → set "App mode" to Live. In development mode Meta sends webhooks only for people with a role on the app.
6. **Give staff the inbox.** In the CRM: Masters & Access → Users → the person → Access → **WhatsApp inbox**: read to see it, write to reply and turn chats into enquiries.

Every webhook post is checked against `META_WA_APP_SECRET`; a post without Meta's signature is refused, so the address can be public.

If messages still do not arrive, link the app to the WhatsApp account and register the number from the server (the WABA ID is in WhatsApp Manager; the PIN is a 6-digit PIN you choose):

```
cd /srv/npt/server && set -a && . ./.env && set +a
curl -X POST "https://graph.facebook.com/v23.0/<WABA_ID>/subscribed_apps" -H "Authorization:
Bearer $META_WA_TOKEN"
curl -X POST "https://graph.facebook.com/v23.0/$META_WA_PHONE_NUMBER_ID/register" \
  -H "Authorization: Bearer $META_WA_TOKEN" -H "Content-Type: application/json" \
  -d '{"messaging_product":"whatsapp","pin":"123456"}'
```

# 13 WhatsApp: message templates

WhatsApp allows free text only within 24 hours of the person's own last message. Anything the app sends first (a quotation, an LR copy, a task notice) must use a template Meta has approved.

1. WhatsApp Manager → "Message templates" → "Create template".
2. For each row: choose the category, type the name exactly, language **English**, paste the body, and give a sample value for every `{{n}}`.
3. Submit. Most are approved within minutes, some within 24 hours.
4. As each is approved, add its line to `.env` and run `pm2 reload npt-api --update-env`.

Keep the placeholders in the order shown; the app fills `{{1}}`, `{{2}}`… in that order. You may change the words around them.

| .env setting | Template name | Category | Body to paste |
|---|---|---|---|
| `WHATSAPP_TEMPLATE_QUOTE` | `quotation_sent` | Utility | Dear {{1}}, please find our quotation {{2}} here: {{3}} — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_LR_COPY` | `lr_copy_sent` | Utility | Dear {{1}}, your goods for {{2}} are dispatched. LR copy: {{3}} — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_TRIP` | `trip_update` | Utility | Dear {{1}}, {{2}} is on its way: {{3}} — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_LOCATION` | `location_request` | Utility | Dear {{1}}, please share your delivery location in this chat so our vehicle can reach you. — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_SAMPLE_READY` | `sample_ready` | Utility | Dear {{1}}, sample {{2}} is ready: {{3}}, {{4}}, quantity {{5}}. {{6}} — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_SAMPLE_DISPATCHED` | `sample_dispatched` | Utility | Dear {{1}}, sample {{2}} ({{3}}, {{4}}, quantity {{5}}) is sent by {{6}}, AWB {{7}}. — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_TASK` | `task_update` | Utility | Task update: {{1}}. {{2}}. Open it: {{3}} — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_TAG` | `query_tagged` | Utility | {{1}} tagged you on query {{2}}. Open it: {{3}} — Navin Plastic Tech |
| `WHATSAPP_TEMPLATE_OTP` | `sign_in_code` | Authentication | Meta's ready-made body, with a "Copy code" button |

Once approved, the `.env` lines are:

```
WHATSAPP_TEMPLATE_QUOTE=quotation_sent
WHATSAPP_TEMPLATE_LR_COPY=lr_copy_sent
WHATSAPP_TEMPLATE_TRIP=trip_update
WHATSAPP_TEMPLATE_LOCATION=location_request
WHATSAPP_TEMPLATE_SAMPLE_READY=sample_ready
WHATSAPP_TEMPLATE_SAMPLE_DISPATCHED=sample_dispatched
WHATSAPP_TEMPLATE_TASK=task_update
WHATSAPP_TEMPLATE_TAG=query_tagged
WHATSAPP_TEMPLATE_OTP=sign_in_code
```

Chose "English (US)"? Set `META_WA_TEMPLATE_LANGUAGE=en_US`, or write it after the name (`quotation_sent:en_US`). Start with Quote, LR copy and Task; they carry most of the daily traffic. OTP is needed only if staff sign in with a phone number.

# 14 WhatsApp: screenshots to draft enquiries

A salesperson or admin forwards a buyer's chat screenshot or visiting card to the business number. The app reads it into a **draft enquiry** and replies with what it read. Nothing becomes a customer until a person checks and confirms it.

## Turn it on

1. Get an API key at `console.anthropic.com` (Settings → API keys) and add it to `.env`:

   ```
   ANTHROPIC_API_KEY=sk-ant-...
   ```

2. Put each salesperson's and admin's WhatsApp number on their user profile: Masters & Access → Users → the person → Phone. **This is how the app knows a photo is from staff.** A photo from any other number is treated as a buyer's message and goes to the inbox.
3. `pm2 reload npt-api --update-env`.

## How staff use it

1. Screenshot the buyer's chat so the name or number at the top shows, or photograph their visiting card.
2. Send it to the business number, up to 3 photos in one message. A caption is optional and is read too.
3. Within about a minute, the app replies with what it read (company, name, mobile, email, place, product, quantity) and a link to the draft.
4. Open the link (or Enquiries → Draft enquiries), correct anything wrong, and fill in the next step, follow-up date and how you met them. An admin can choose the salesperson in the **Marketing person** field.
5. Click **Confirm**: the customer and first enquiry are created.

- **Long chats:** send the screenshot with the buyer's name first; ones sent within 10 minutes join the same draft.
- **Existing buyers:** if the phone or email already belongs to a customer, the reply says so and Confirm is refused; raise the enquiry on that customer.
- **No key or blurred photo:** the draft is still saved, with the reason, for typing in by hand.
- **Without WhatsApp:** the same reading works by uploading the photo on the Draft enquiries screen.

# 15 Test it end to end

Use your own phone as the "buyer". Do these in order; the first that fails tells you where to look.

| # | Test | How | Pass when |
|---|---|---|---|
| 1 | Web app on HTTPS | Open https://crm.navinplastic.com and sign in | Padlock in the address bar; dashboard loads |
| 2 | API and database | `curl -s https://api.navinplastic.com/health/ready` | `"transactions": true` |
| 3 | Email | Sign out; "Forgot password" for your email | The email arrives |
| 4 | Server sees Meta | Same health URL | `"whatsapp": "meta"` |
| 5 | Sending | Add `WHATSAPP_LOGIN_PING=<your mobile>` to `.env`, reload, sign in | Meta's `hello_world` arrives. Then remove the line |
| 6 | Webhook | Send "Hi" from your phone to the business number | It appears in the WhatsApp inbox in seconds |
| 7 | Replies | Answer it from the inbox | It arrives on your phone |
| 8 | Templates + PDF | Test customer with your mobile → quotation → send by WhatsApp → tap the link | Message arrives; PDF opens; send log reads Sent |
| 9 | Staff notices | Your mobile on a staff profile; raise a department task to them | The task notice arrives |
| 10 | Screenshots | From a staff phone, send a visiting card photo | Reply with what was read; draft appears |

```
pm2 logs npt-api | grep -i whatsapp      # watch while testing; Ctrl C to stop
```

# 16 Troubleshooting

## Server and domain

| What you see | Cause and fix |
|---|---|
| Browser says "site can't be reached" | DNS not pointing yet (`dig`, Part 4.3), or ports 80/443 missing from the security group |
| Certbot fails: "DNS problem" or "connection refused" | The names do not resolve to the Elastic IP yet, or port 80 is closed. Wait, check, retry |
| Every action fails; browser console says CORS | `CORS_ORIGIN` must equal the web address exactly: `https://`, no trailing slash. Reload with `--update-env` |
| Screens load but nothing saves (404s) | `VITE_API_URL` was wrong when built. Fix `.env.production` and run `npm run build` again |
| Reloading a page gives Nginx 404 | The `try_files` line is missing from the web app's server block |
| Photo uploads fail around 1 MB | `client_max_body_size 25M;` missing from the API block |
| `pm2 status` shows restarts climbing | `pm2 logs npt-api`: usually a wrong `MONGO_URI` password or a missing `.env` value; the log names it |
| API refuses to start: CORS or JWT message | In production the API needs a real `CORS_ORIGIN` (not `*`) and a `JWT_SECRET` of 32+ characters |
| Whole server freezes during a build | Out of memory: check swap is on (`free -m`); on t3.small run one API process (`pm2 status` shows one `npt-api` row) |
| `"transactions": false` | Part 5.6 not done, or `&replicaSet=rs0` missing from `MONGO_URI` |
| Sign-in codes/emails never arrive | SMTP host, port or password; the log names the setting. Gmail needs an App Password |

## WhatsApp

A failed send shows its reason on the send log in the app; `pm2 logs npt-api` has Meta's error code.

| What you see | Cause | Fix |
|---|---|---|
| Health shows `whatsapp: console` | Token or phone number ID missing, or no reload | Check both lines; `pm2 reload npt-api --update-env` |
| "Callback URL couldn't be validated" | Verify token differs, not set, or API not on HTTPS | Paste the token again without spaces; reload; retry |
| Verified, but nothing reaches the inbox | Not subscribed to **messages**, app not Live, or app not linked | Part 12.3 steps 4–5, then the subscribe command |
| 401 "Bad webhook signature" | `META_WA_APP_SECRET` wrong | Copy it again from App settings → Basic |
| Error 190 | Token expired (the 24-hour one) | System User token with expiry Never |
| Error 10 or 200 | Token lacks WhatsApp permission | Generate again with `whatsapp_business_messaging` |
| Error 100 / 131030 | Wrong phone number ID / still the test number | Copy the ID under your real number |
| Error 133010 | Number not registered for the Cloud API | The register command in Part 12.3 |

| | | |
|---|---|---|
| Error 131047 or 470 | Outside 24 hours with no template | Approve and set that template (Part 13) |
| Error 132001 / 132000 | Template name/language wrong / placeholder count differs | Match the name exactly; recreate with the Part 13 placeholders |
| Error 131052 | Meta could not download the PDF | `PUBLIC_API_URL` must be the public HTTPS API address |
| Error 131026 | The buyer's number is not on WhatsApp | Check the number on the customer record |

# A Go-live checklist

## Server

☐ t3.small (or larger) in Mumbai, 40 GB gp3, Elastic IP attached

☐ Security group: SSH from your IP only; 80 and 443 open; 27017 and 5000 closed

☐ Swap on (`free -m`), firewall on (`sudo ufw status`)

☐ MongoDB with a password and replica set: health shows `"transactions": true`

☐ `.env` filled, `chmod 600`, not in git; `OTP_EXPOSE_IN_RESPONSE=false`

☐ pm2 running and saved; `pm2 startup` line run (survives a reboot: test with `sudo reboot`)

## Domain

☐ A records for `crm` and `api` point at the Elastic IP; email records untouched

☐ HTTPS padlock on both names; `certbot renew --dry-run` succeeded

☐ `CORS_ORIGIN`, `APP_URL`, `PUBLIC_API_URL`, `VITE_API_URL` and the Nginx CSP all use the same names

## Data safety

☐ Nightly backup to S3 runs (check the bucket the next morning); versioning on

☐ A restore was tried once on purpose

☐ Weekly `df -h /` or a CloudWatch disk alarm at 75%

## WhatsApp

☐ Business verified; display name approved; billing card added

☐ Permanent System User token; health shows `"whatsapp": "meta"`

☐ Webhook verified, **messages** subscribed, app Live

☐ Quote, LR copy and Task templates approved and set

☐ Staff numbers on their user profiles; WhatsApp inbox access granted

☐ All ten tests in Part 15 pass

## People

☐ Admin account created; staff added with departments

☐ Staff told the address: https://crm.navinplastic.com (on phones: browser menu → "Install app" / "Add to Home screen")

> More detail: `docs/DEPLOY-AWS.md` (server, automatic deploys), `docs/SCALING.md` (growing beyond one server) and `docs/PRODUCTION-READINESS.md` (load and security test results) in the server repository.